SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Accredited by NAAC A Grade

Assignment I

CO1: Apply the foundational concepts of ethical hacking — types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cyber security.

Evaluation note: This is a design/portfolio assignment. Each task is marked on the evidence listed in the question paper. Award marks for correct governance decisions, working artefacts (tables, workflows, documents, lab design) and demonstrated integration between components — not for listing tools. Accept equivalent correct designs.

Name of the Student : A Sweety Roselin

Register No : 192324164

Department : AI & DS

Sub Code / Name : ITA1405 – Ethical Hacking

Date of Submission : 4/11/2026

Total Marks:

Sweety Roselin A

Student Signature **Faculty Signature**

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

---

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

1.1 Scenario-derived governance requirements

The university plans to assess approximately 20 systems and 50 staff before a major upgrade. The initial scope includes the student portal, learning-management system (LMS), university email service and an authorized campus-network segment. The framework must be reusable as the programme grows.

Requirement area	Requirement identified	Governance response / evidence
Systems	Student portal, LMS, email, campus network and supporting assets (about 20 initially).	Asset register with unique asset IDs, owner, environment and scope tag.
People	Management/CISO, department heads, system owners, internal testers, external assessors, DPO/privacy lead, IT operations, students and staff as data subjects.	RACI/role assignment, approval matrix, assessor onboarding and named contacts.
Activities	Reconnaissance, scanning, enumeration, controlled lab testing, finding documentation and responsible disclosure.	Approved methodology, lab record, finding report and disclosure log.
Constraints	Personal data, live-service availability, third-party ownership, limited windows, no live exploitation under this assignment.	Written authorization, data minimisation, stop conditions, change window and exclusions.
Growth	Whole-university coverage and third-party assessors.	Reusable templates, central register, delegated approval and audit trail.

1.2 Systems and initial boundaries

System group	Examples	Initial treatment
Student portal	Authentication, profile, course/fee pages	In scope for design review; hands-on exploitation only against a lab replica.
LMS	Login, course materials, assignment upload	In scope; use synthetic student and course data in lab.
Email service	Webmail, identity integration, mail security configuration	Configuration review and lab simulation; no real phishing or mailbox access.
Campus network	Only named campus subnets / test VLANs	Asset IDs and CIDR ranges must be listed in the signed RoE.
Supporting systems	Servers, identity provider, databases, backup, DNS	Out of scope unless individually listed and approved.
Third-party services	Cloud-hosted platforms,	Excluded unless the provider

	payment gateway, SaaS	and university give written permission.

1.3 Stakeholders and responsibilities

Stakeholder	Main responsibility
University management / CISO	Owns programme policy, approves high-risk engagements and accepts residual risk.
Department head / requester	Submits business need, desired outcomes and proposed assessment window.
System owner	Confirms asset ownership, criticality, maintenance windows and operational contacts.
Ethical-Hacking Governance Team	Checks authorization, scope, risk, documentation, evidence quality and closure.
Internal tester	Works within the approved scope and records all activity.
External assessor	Completes vetting, NDA, conflict checks, authorization and least-privilege onboarding.
DPO / privacy or legal lead	Reviews personal-data exposure, retention, confidentiality and applicable legal obligations.
IT operations / incident response	Monitors service health, receives stop notices and handles any unintended incident.
Students and staff	Data subjects whose information must be protected; are not targets without specific approval.

1.4 Expected activities and constraints

1. Submit a documented request and identify the business purpose, assets, owners and requested dates.
2. Verify the approver's authority and issue a unique Engagement ID before any assessment activity.
3. Tag assets as IN-SCOPE, OUT-OF-SCOPE or PENDING-APPROVAL; check the tag before each action.
4. Complete legal, privacy, operational-risk and third-party permission checks.
5. Model relevant threat actors and define the assessment objectives.
6. Use the isolated lab for hands-on exploitation demonstrations; production systems receive only explicitly approved, non-disruptive review activities.
7. Record findings with evidence minimised to avoid real personal data; assign severity and remediation owner.
8. Use coordinated disclosure, track remediation and retest only under renewed/continuing authorization.

1.5 Integrated framework blueprint

Stage	Input	Action / control	Output passed to next stage
1. Request & authorization	Department request	Governance review; system owner, CISO and required privacy/legal approvals; signed authorization.	Engagement ID and approval record.
2. Scope & RoE	Approved request	Asset-tag check, dates, permitted/prohibited methods, stop conditions and escalation contacts.	Signed scope and RoE.
3. Legal & privacy gate	Scope and data classification	Map IT Act, DPDP transition, CERT-In duties, contracts and third-party terms.	Legal/privacy clearance and handling conditions.
4. Threat model	System architecture and objectives	Classify likely actors by authorization, intent, capability and affiliation.	Threat scenarios and test priorities.
5. Isolated lab	Approved test cases	Use Kali and intentionally vulnerable targets on host-only network; capture configuration and logs.	Lab evidence and safe validation results.
6. Finding report	Observed weakness / lab evidence	Record affected asset, severity, evidence, impact and remediation.	Structured finding record.
7. Disclosure & remediation	Finding record + legal/RoE constraints	Notify authorized owner privately, set deadline, track fix, escalate overdue findings.	Disclosure log, remediation status and retest approval.
8. Governance review	Engagement record and outcomes	Audit completeness, lessons learned, update asset register and metrics.	Closure approval and framework improvement.

Governance layer: a central engagement register records approvals, scope versions, legal decisions, tester identities, activity logs, findings, disclosure dates and closure. Findings feed back into risk priorities and future scope. This makes the components operate as one system rather than separate documents.

1.6 Enquiry questions

9. Who has authority to approve an assessment, and how is written authorization recorded and verified?
10. Which assets, network ranges, environments and testing techniques are in scope or excluded?
11. Which Indian laws, regulations, contracts and international rules may apply, especially where personal data or third-party services are involved?
12. How are white-hat, black-hat, grey-hat, insider and other threat actors classified and mapped to university risks?
13. How can practical testing be validated without affecting live student, teaching or administrative services?
14. Who receives a vulnerability report, what remediation window applies, and when may any disclosure proceed?

1.7 Design criteria / acceptance tests

ID	Acceptance criterion	Pass evidence
C1 – Authorization	Every engagement has verifiable written authorization before activity.	Signed authorization; approver identity; Engagement ID; start gate.
C2 – Scope	Scope is explicit, asset-tagged and machine-checkable.	Asset register; out-of-scope test rejected by workflow.
C3 – Legal mapping	Every identified legal requirement is linked to a practical control.	Legal-control matrix and DPO/legal decision record.
C4 – No live harm	Hands-on exploitation is confined to isolated lab; production actions are separately limited and approved.	Host-only lab record; no production exploit evidence.
C5 – Disclosure	Every finding has a report format, recipient, timeline and escalation path.	Finding report and disclosure register.
C6 – Scalability	The framework supports university-wide scope and external assessors with auditable records.	Reusable forms, onboarding checklist, central log and scale evaluation.

Rationale: the framework directly addresses the scenario's main risks—unauthorized access, legal exposure, service damage, unclear scope and uncoordinated disclosure. The trade-off is additional approval effort; this is accepted because the cost of uncontrolled testing is higher.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Classification criteria

Each actor is classified using four attributes: (1) authorization – yes/no/unclear; (2) intent – benign, mixed or malicious; (3) capability – low, medium or high; and (4) affiliation – external, internal or state-linked. The label describes behaviour and risk, not merely the tool used.

Actor type	Motivation	Typical capability	Likely university targets	Risk treatment
White-hat	Improve security with permission.	Medium–high; disciplined and scoped.	Approved portal, LMS, email and network assets.	Permit only under signed authorization and RoE.
Black-hat	Financial gain, theft, disruption or damage.	Medium–high; malicious and persistent.	Student records, credentials, email, finance and research data.	Prevent, detect, contain and investigate.
Grey-hat	Curiosity or recognition; acts without clear permission; may report later.	Low–high; variable.	Public portal, exposed services and misconfigured systems.	Treat as unauthorized; do not rely on claimed good intent.
Script kiddie	Thrill, status or experimentation using ready-made tools.	Usually low; limited understanding.	Exposed login pages, web services and Wi-Fi.	Patch, rate-limit, monitor and educate.
Hacktivist	Political or social message; publicity or protest.	Medium; may coordinate campaigns.	Public website, admissions pages, social channels and email.	Monitor exposure, prepare communications and continuity.
Insider	Grievance, financial gain, coercion or careless behaviour.	Medium; legitimate access and contextual knowledge.	HR/finance, student records, shared drives and admin systems.	Least privilege, separation of duties and audit logs.
State-sponsored	Espionage, strategic intelligence or influence.	High; stealthy, resourced and persistent.	Research data, intellectual property, senior accounts and sensitive records.	Threat intelligence, segmentation, MFA and incident response.

2.2 Threat scenarios and priorities

Scenario	Actor most associated	Assets at risk	Defensive priority
Credential stuffing / password reuse	Black-hat or script kiddie	Student portal and email	MFA, rate limits, breached-password checks and alerting.
Unauthorized probing	Grey-hat or script	Student portal / LMS	Exposure management and clear vulnerability-

of public web service	kiddie		reporting channel.
Website defacement	Hacktivist	Public university website	Secure publishing, backups and rapid restoration.
Abuse of privileged account	Insider	HR, finance, student records	Privileged access management and immutable logs.
Long-term research-data theft	State-sponsored actor	Research servers and identity systems	Network segmentation, endpoint detection and access review.

2.3 Borderline actor – alternative classifications

Case: a student discovers a weakness in the student portal without permission, uses a publicly available scanner to confirm that a page behaves unexpectedly, and privately reports the issue to the university without copying records or demanding payment.

Alternative	Reason it could fit	Limitation
Alternative A – Script kiddie	The student may have used a ready-made tool and may have limited technical skill.	This label focuses on capability and does not capture the defining authorization/intent issue.
Alternative B – Grey-hat	The student acted without authorization but appears to have non-malicious intent and reports the weakness.	This better captures the ethical and authorization boundary.

Final classification: Grey-hat. The decisive attributes are no authorization and apparently non-malicious intent. The university must still treat the activity as unauthorized, preserve evidence and handle the report through its intake process. If the student threatens disclosure unless paid, the assessment of intent changes and may move toward black-hat/extortion behaviour. A good-faith report does not retroactively authorize testing.

2.4 Threat-model output

For each engagement, the threat model records actor, motivation, capability, access path, target asset, likely impact, existing controls, residual risk and recommended test objective. The model informs the scope and lab scenarios; it does not grant permission to test a real actor or system.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Reusable code of conduct

- Written authorization: do not begin without a signed approval record and unique Engagement ID.
- Agreed scope: test only assets, accounts, methods and dates listed in the approved RoE.
- Confidentiality: protect university, student, staff and research information; share only with approved recipients.
- Integrity of evidence: preserve accurate timestamps, logs and hashes where appropriate; never fabricate, alter or conceal results.
- Avoid harm: use least-intrusive methods; do not disrupt teaching, admissions, payroll, examinations or emergency services.
- Data minimisation: do not browse, copy, download or retain personal data; stop if real personal data is unexpectedly exposed.
- Honest reporting: report all relevant findings, limitations, false positives and mistakes accurately.
- Accountability: log material actions; use dual approval for high-risk steps; keep credentials and test data secure.
- Stop-work duty: immediately stop on unexpected instability, out-of-scope access, personal-data exposure or instruction from the engagement lead.
- Responsible disclosure: do not publish, sell, exploit or privately share findings outside the approved disclosure channel.

3.2 Preventive checks and decision rules

Check	Decision rule	Evidence
Authorization gate	No valid Engagement ID and signed approval → no activity.	Authorization register.
Scope gate	Target must be tagged IN-SCOPE and match the signed scope version; otherwise block.	Asset register / scope validation.
Time-window gate	Activity must occur within the approved window.	Schedule and activity log.
Technique gate	Technique must be permitted; prohibited technique → reject or seek a new approval.	RoE and test plan.
Data gate	Unexpected personal data → stop, do not copy, notify lead/DPO and follow incident procedure.	Data exposure event record.
Sensitive action gate	High-risk action requires written change approval and two-person review; lab only for exploit demonstration.	Change approval.
Evidence gate	Store only minimum evidence in access-controlled repository.	Evidence index and access log.
Closure gate	All findings disclosed to owner, artifacts secured and access revoked.	Closure checklist.

3.3 Scenario test cases

Action / scenario	Classification	Code response
Testing an in-scope lab target with valid written authorization.	Acceptable	Proceed within scope; log activity and preserve evidence.
A listed portal host links to a non-listed payment-provider host.	Borderline	Do not follow or test the external host; record the link and request separate permission.
A tester discovers an unlisted server responds on the campus network.	Borderline	Stop interaction; report to governance; update scope only after formal approval.
Tester uses discovered credentials to access another system.	Unacceptable	Prohibited; halt engagement, preserve minimal evidence and escalate.
Tester copies real student records to prove impact.	Unacceptable	Prohibited; stop, do not retain data, notify DPO/security lead and follow incident response.
Tester reports a critical vulnerability privately to the designated owner.	Acceptable	Create finding record, assign urgent remediation and track the deadline.

3.4 How the module preserves trust

The module protects students and staff by limiting data exposure, protects system owners through agreed windows and stop conditions, and protects testers by ensuring the permission and limits are documented. It also makes decisions auditable. The university should treat a breach of the code as a governance incident, not as an informal disagreement.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

This section is an educational compliance map, not legal advice. The university's legal counsel must confirm the applicability of each law to its legal entity, contracts, data flows and the date of each engagement. The US CFAA is included as an international comparison; it does not automatically govern an India-only assessment.

4.1 India legal and regulatory mapping

Law / provision	Relevance to engagement	Framework control
IT Act 2000, s.43	Accessing, copying, downloading, introducing contaminants or damaging a computer resource without permission can attract compensation/penalty consequences.	Signed authorization; strict asset scope; no data extraction; change and stop controls.
IT Act 2000, s.66	Dishonest or fraudulent acts described in s.43 can become computer-related offences; statutory punishment can extend to 3 years or fine up to ₹5 lakh or both.	Authorization verification, tester identity, activity logging and evidence preservation.
IT Act 2000, s.66C	Fraudulent/dishonest use of another person's password or unique identification feature; up to 3 years and fine up to ₹1 lakh.	No real-user credential reuse; synthetic test accounts; MFA and credential-handling rules.
IT Act 2000, s.66D	Cheating by personation using a computer resource; up to 3 years and fine up to ₹1 lakh.	No impersonation or phishing of real users unless separately and lawfully authorized.
IT Act 2000, s.72	Breach of confidentiality and privacy by a person who obtains access under powers of the Act; current statutory text and conditions must be checked by counsel.	Confidentiality, least privilege, restricted evidence access and controlled disclosure.
IT Act 2000, s.72A	Disclosure of personal information in breach of lawful contract with wrongful-loss/gain intent or knowledge; current penalty provision can extend to ₹25 lakh.	NDA, contractual confidentiality, named recipients and secure report transfer.
IT Act 2000, s.43A and SPDI Rules 2011	At the current transition date, s.43A remains listed as in force; it addresses negligence in reasonable security practices for sensitive personal data handled by a body corporate. Application depends on the	Data minimisation, reasonable security controls, secure storage, DPO/legal review and vendor clauses.

	entity and facts.	
DPDP Act 2023 and DPDP Rules 2025	The Act has a phased commencement. As of 4 Nov 2026, the main processing duties in ss.3–17 are scheduled to commence 18 months after 13 Nov 2025 (13 May 2027); other listed provisions commenced earlier. Prepare now and re-check at engagement date.	DPDP readiness checklist, purpose limitation, access restriction, retention/deletion and breach workflow; legal review of commencement.
CERT-In Directions 2022 under IT Act s.70B	Applicable entities must report specified cyber incidents within 6 hours of noticing or being informed and maintain ICT logs securely for a rolling 180 days within Indian jurisdiction, subject to the Directions and applicability.	Incident escalation matrix, named CERT-In point of contact, incident clock, log retention and secure handover.

4.2 Offences, obligations and penalties – indicative summary

Issue	India – IT Act	US – CFAA (18 U.S.C. §1030)	Penalty / note
Unauthorized access / obtaining information	s.43; s.66 if dishonest/fraudulent.	§1030(a)(2) covers intentional unauthorized access / exceeding authorized access and obtaining specified information.	India s.43 civil compensation/penalty; s.66 up to 3 years / ₹5 lakh or both. CFAA penalties vary by subsection and facts.
Fraudulent access / value obtained	s.66.	§1030(a)(4).	India s.66 up to 3 years / ₹5 lakh or both. CFAA first offence under (a)(4) can carry up to 5 years; repeat up to 10 years.
Identity theft / impersonation	ss.66C and 66D.	Related federal identity-fraud provisions may apply; CFAA may also apply depending on conduct.	India ss.66C/66D up to 3 years and fine up to ₹1 lakh.
Damage / impairment	s.43; s.66 where dishonest/fraudulent.	§1030(a)(5).	India compensation/penalty and potentially s.66. CFAA penalties vary with damage, loss and aggravating factors.
Confidentiality / disclosure	ss.72 and 72A; contractual and data-	No single direct equivalent; other US	India s.72A current penalty can extend to

	protection duties.	privacy, trade-secret and state laws may apply.	₹25 lakh; s.72 wording and application must be reviewed.
Sensitive personal data protection	s.43A and SPDI Rules 2011 during applicable transition; DPDP Act phased commencement.	Sectoral and state privacy laws may apply in the US; not equivalent to DPDP.	Apply the law in force at the time and assess university/entity status.

Penalty note: the table is deliberately not a complete sentencing schedule. CFAA penalties differ by subsection, prior convictions, loss, damage and aggravating circumstances. IT Act amendments may also change the form of penalty. The legal team must consult the current consolidated text before approving a real engagement.

4.3 Personal-data decision

If the assessment touches a system that holds personal data, the legal/privacy review is mandatory even if the planned test uses synthetic data. The team must identify whether the activity could expose personal data, whether the university is a data fiduciary or processor in the relevant flow, whether a vendor contract applies, and which provisions are in force on the test date. Until legal clearance is recorded, the test is limited to a lab replica with synthetic data.

Transition point: the Gazette notification dated 13 November 2025 phases the DPDP Act provisions. The principal processing provisions (including sections 3–17) are scheduled for commencement 18 months after publication, i.e. 13 May 2027. Some institutional and procedural provisions commenced on publication; section 6(9) and section 27(1)(d) are scheduled one year after publication. Therefore the framework adopts DPDP-aligned safeguards immediately as readiness controls but does not incorrectly state that all substantive duties are already operative on 4 November 2026.

4.4 Legal requirements linked to control

Legal trigger	Control / evidence	Owner
Unauthorized access risk (ss.43/66)	Signed permission, Engagement ID, asset allow-list, scope check and activity logs.	CISO / Governance Lead
Credentials / personation (ss.66C/66D)	Synthetic accounts, no credential reuse, no real-user phishing absent separate approval.	System owner / Test Lead
Personal / sensitive data (s.43A, SPDI, DPDP transition)	Data classification, minimisation, lab replicas, DPO/legal review, encryption and deletion schedule.	DPO / Data Owner
Confidentiality / contract (ss.72/72A, NDA)	Confidentiality terms, secure report repository and recipient verification.	Legal / Governance Lead
Specified cyber incident (CERT-In Directions)	Incident triage, six-hour reporting assessment, point of contact and 180-day log	Incident Response Lead

	retention.	

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Reusable Scope and RoE document

Field	Default / example value
Engagement ID	UNI-SEC-YYYY-NNN (issued only after approval)
Requesting department	[Department name]
Business purpose	Pre-upgrade security assessment of university services
Engagement owner	[CISO / Governance Lead]
Test lead / assessor	[Name, employer, contact, vetted status]
Start and end	[Approved dates and local time zone]
Testing window	Off-peak window approved by system owner; no activity outside window.
In-scope assets	Asset IDs and exact hostnames/IP/CIDR listed in signed Appendix A.
Out-of-scope assets	Any unlisted host, production database with live personal data unless separately approved, third-party hosted service without provider permission, staff personal devices and external networks.
Permitted methods	Document review, passive reconnaissance, approved scanning and enumeration within listed assets; exploit demonstration only against isolated lab targets.
Prohibited methods	Denial of service, destructive testing, persistence, malware deployment, data exfiltration, credential theft, real-user phishing, social engineering and out-of-scope testing.
Data handling	Use synthetic data; if real personal data appears unexpectedly, stop, do not copy, notify DPO/security lead and follow incident procedure.
Availability controls	Rate limits, off-peak windows, service-health monitoring and immediate stop on instability.
Escalation contacts	System owner, test lead, CISO/SOC, DPO and emergency contact: [names and numbers].
Evidence storage	Encrypted approved repository; role-based access; retention/deletion date recorded.
Signatures	Requester, system owner, CISO/authorized approver, legal/DPO if required, test lead and third-party representative.

5.2 Asset naming and scope boundary

Every asset receives a stable ID and one of three tags: IN-SCOPE, OUT-OF-SCOPE or PENDING-APPROVAL. Example: UNI-PORTAL-PRD-001 (production portal) and UNI-LAB-PORTAL-001 (lab replica). The signed scope includes exact hostname/IP/CIDR, owner, environment and approved method. Wildcard domains, adjacent subnets and linked third-party hosts are not implicitly included.

Asset ID	Description	Scope tag	Owner	Permitted activity
UNI-PORTAL-LAB-001	Student portal replica	IN-SCOPE	Application owner	Lab scanning and controlled validation
UNI-LMS-LAB-001	LMS training replica	IN-SCOPE	LMS owner	Lab scanning and controlled validation
UNI-MAIL-PRD-001	Production email service	PENDING-APPROVAL	IT operations	Configuration review only after explicit approval
UNI-PAY-EXT-001	External payment gateway	OUT-OF-SCOPE	Third-party provider	None without provider and university approval

5.3 Authorization verification rules

15. Confirm the signer is listed in the university approval matrix and has authority over the named asset.
16. Confirm the approval is signed, dated, versioned and unexpired; retain the signed copy in the engagement register.
17. Match every requested target to an IN-SCOPE asset tag and the approved scope version.
18. Check that all required system-owner, CISO, legal/DPO and provider approvals are present.
19. Check tester identity, employer, NDA, training and access expiry.
20. Do not start if any approval, asset owner, date, scope boundary or emergency contact is missing.
21. Any scope change requires a documented change request, risk review, re-approval and updated RoE version.

5.4 Escalation and stop-work process

Trigger	Immediate action	Notify
Unexpected service slowdown or outage	Stop tests; preserve timestamps and non-sensitive logs; do not resume until cleared.	System owner, test lead, SOC/CISO.
Out-of-scope asset appears	Do not probe further; record hostname/IP only if already visible; request scope decision.	Governance Lead and system owner.
Personal data exposed	Stop interaction; do not copy or screenshot data; secure the minimum event record.	DPO, CISO, legal and incident response.
Suspected real incident	Stop assessment and hand over to incident response; preserve evidence.	SOC/CSIRT and CISO.
Approval revoked	Immediately stop and revoke access/tokens; confirm cessation.	Approver, system owner and Governance Lead.

5.5 Derived pre-engagement checklist

- ☐ Signed authorization and Engagement ID verified.
- ☐ Asset inventory checked; every target is tagged IN-SCOPE.
- ☐ Scope version, test dates, time window and permitted methods confirmed.
- ☐ Third-party permissions and assessor NDA/vetting completed where applicable.
- ☐ Legal/privacy review completed; data classification and handling rules approved.
- ☐ System owner, test lead, SOC, DPO and emergency contacts confirmed.
- ☐ Isolated lab is ready; no route to production or public internet.
- ☐ Test accounts and synthetic data prepared.
- ☐ Logging, evidence repository, access controls and retention dates configured.
- ☐ Stop-work procedure and escalation channel tested.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow

Step	Responsible party	Required action / decision	Status output
1. Request	Department requester	Submit purpose, systems, risk, dates, expected outcome and data types.	REQUESTED
2. Governance review	Governance Team	Check completeness, assessor, asset IDs, conflicts and risk category.	UNDER REVIEW / RETURNED
3. System-owner review	System owner	Confirm ownership, availability, maintenance window and impact limits.	OWNER APPROVED / REJECTED
4. Legal/privacy review	Legal and DPO	Review personal data, contracts, provider permissions and applicable law.	LEGAL CLEARED / HOLD
5. Final approval	CISO / delegated approver	Approve scope, methods, dates and stop conditions.	APPROVED
6. Sign and record	Governance administrator	Issue Engagement ID; store signatures, scope version and evidence.	AUTHORIZED
7. Execute and monitor	Test lead / SOC	Check gates, log activities, monitor service health and handle stop requests.	IN PROGRESS / PAUSED
8. Close	System owner / CISO	Review findings, remediation, access revocation and lessons learned.	CLOSED

Hard gate: no valid Engagement ID, no signed authorization, missing owner approval, unresolved legal hold or out-of-scope asset means the workflow cannot enter AUTHORIZED.

6.2 Responsible / coordinated disclosure process

Timeline	Action	Owner / record
T0 – discovery	Create a finding ID; record asset, timestamp, severity, impact and minimum evidence.	Tester; Finding Report
Within 1 business day for critical; 3 business days for others	Privately notify the named system owner and CISO through the approved channel.	Test Lead; Disclosure Record
Triage target: 2 business days	Validate severity, exploitability,	Security Governance / System

critical; 5 business days others	exposure and whether a reportable incident occurred.	Owner
Remediation target: 30 days critical; 90 days high/medium/low by default	Agree fix plan, compensating controls, owner and due date; critical risk may require immediate mitigation.	System Owner; Remediation Tracker
Before deadline	Provide status updates; escalate overdue critical findings to CISO and management.	Governance Lead
After fix	Retest only under authorization; record pass/fail and residual risk.	Authorized Tester
Closure	Close only after owner acceptance, evidence storage and access revocation.	CISO / Governance Lead

These are programme service-level targets, not statutory safe harbours. A critical vulnerability may require immediate containment rather than waiting 30 days. Any actual cyber incident must be assessed separately against applicable CERT-In reporting requirements.

6.3 Disclosure approaches compared

Approach	How it works	Advantages	Risks / suitability
Coordinated disclosure (chosen default)	Private report to owner; remediation period; public notice only after coordinated decision.	Protects users while allowing remediation and verification.	Requires trusted contacts and deadline management; best fit for university.
Full disclosure	Details are published publicly, potentially before a fix.	Can create pressure for action and inform defenders.	Can enable exploitation and expose students; not default for university findings.
Bug bounty	Pre-authorized programme pays eligible reporters for in-scope findings.	Clear intake rules and incentives; scales external reporting.	Needs budget, triage capacity, strict scope and payment governance; separate programme approval required.

6.4 Disclosure decision rules

22. Default to coordinated private disclosure to the named system owner and CISO.
23. Check the signed RoE: disclose only findings from the approved engagement and only to authorized recipients.
24. Check the legal/privacy classification: findings involving personal data, credentials or sensitive research remain restricted; do not publish evidence containing such data.
25. Assess whether the finding is also a cyber incident; if so, invoke incident response and determine CERT-In reporting applicability and timeline.

26. At deadline, escalate to CISO and legal; agree an extension, compensating control or limited advisory. Do not automatically publish.
27. Public disclosure is exceptional and requires written CISO, legal and DPO approval, risk review, redaction and confirmation that disclosure will not expose personal data or materially increase harm.
28. Any disclosure to a third-party vendor must follow contractual notification and provider rules.

6.5 Logging operations / pseudocode

logApproval(engagement): verify signer authority; store Engagement ID, signed scope version, approver, timestamp and conditions; append immutable audit event.

updateStatus(record, newStatus): validate allowed state transition; store actor, timestamp, reason and supporting evidence.

canDisclose(finding): return TRUE only if recipient is authorized, RoE permits the disclosure, legal/privacy review is clear, evidence is redacted and required approvals are recorded. Public disclosure additionally requires explicit exceptional approval.

6.6 Interaction with RoE and legal layer

The disclosure module reads the asset ID and scope version from the RoE. It rejects a finding from an out-of-scope asset. It also reads the legal/privacy flag. If personal data is involved, the finding remains private and is routed to the DPO/legal lead. The disclosure module therefore cannot operate independently of authorization, scope and legal compliance.

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab architecture

The lab uses a Kali Linux tester VM and one or more deliberately vulnerable target VMs such as DVWA or Metasploitable. All VMs connect to a VirtualBox Host-Only network using 192.168.56.0/24. The host-only segment has no default gateway and no bridge to the university production network.

Component	Role	Address / setting
Kali Linux VM	Authorized tester workstation	192.168.56.10/24
DVWA target VM	Intentionally vulnerable web application	192.168.56.20/24
Optional second target	Additional training target	192.168.56.30/24
Host-only virtual switch	Private VM-to-VM network	192.168.56.0/24; no gateway
Hypervisor host	Manages VMs and snapshots	Host-only adapter; no forwarding/bridging

Connectivity: Kali ↔ Host-only virtual switch ↔ DVWA/target VM. No path is configured from the lab subnet to production or the public internet. Disable shared folders, shared clipboard and drag-and-drop unless required and explicitly controlled. Use snapshots and synthetic data.

7.2 Roles and configuration recording

Role	Responsibility
Lab administrator	Creates host-only network, checks adapter mode, snapshots VMs and documents configuration.
Tester	Uses Kali only against approved lab target IPs; records commands and timestamps.
Observer / reviewer	Checks target allow-list, validates no external route and reviews evidence.
Governance Lead	Confirms lab test is tied to an authorized Engagement ID and approved test case.

7.3 Safe verification operations

Operation 1 – verify interface and target reachability (run inside the isolated lab only):

```
ip -br addr
ip route
ping -c 4 192.168.56.20
```

Expected result: Kali has 192.168.56.10/24, the target is reachable at 192.168.56.20, and the routing table has no default route via the host-only adapter. If the target does not respond, troubleshoot the VM network settings rather than scanning other networks.

Operation 2 – record lab configuration and confirm the target allow-list:

```
mkdir -p ~/lab-evidence
ip -br addr > ~/lab-evidence/interfaces.txt
ip route > ~/lab-evidence/routes.txt
```

```
nmap -sn 192.168.56.20 -oN ~/lab-evidence/target-discovery.txt
date -Is > ~/lab-evidence/capture-time.txt
```

The discovery command above is limited to the single designated lab target address. Store the output with the Engagement ID and do not run it against any production or public network.

Operation 3 – capture a snapshot and record VM settings: record VM names, adapter type (Host-only), MAC addresses, IP addresses, snapshot ID, OS versions and date. Export or screenshot the hypervisor network configuration for the lab evidence pack.

7.4 Host-only versus NAT

Aspect	Host-only (chosen)	NAT
Internet access	No internet access by default; isolated VM-to-VM network.	VM can reach internet through host NAT.
Risk of traffic leakage	Very low when no bridging/forwarding is configured.	Higher because traffic can leave through host.
VM-to-VM testing	Direct within isolated subnet.	Possible depending on NAT/NAT Network configuration.
Convenience	Requires separate controlled update process.	Convenient for package updates.
Suitability	Best for contained security testing.	Useful for updates but not the safest default for exploit lab.

Chosen design: Host-only. If updates are required, use a separate temporary maintenance procedure or offline packages, then disconnect the update interface before testing. Do not leave a NAT adapter attached during the assessment.

7.5 How the lab preserves authorization and containment

- Every lab target is explicitly named in the engagement scope and uses a reserved lab IP.
- The lab has no default route, bridged adapter, port forwarding or connection to production.
- Only synthetic data and training credentials are used.
- Snapshots permit recovery and reproducibility.
- Commands and outputs are logged and linked to the Engagement ID.
- Any unexpected host or route causes immediate stop and configuration review.

TASK 8 – Develop a Reusable Document Library (4 Marks)

The following reusable templates form the programme's document library. Bracketed fields are completed for each engagement. The Finding Report produces a structured record consumed by the disclosure register and Task 10 metrics.

8.1 Document 1 – Authorization Form

Field	Template value / instruction
Engagement ID	[Issued by Governance Team after approval]
Requesting department / requester	[Name, role, department, contact]
Purpose and business justification	[Why the assessment is required]
Systems / asset IDs	[Exact asset IDs, hostnames, IPs/CIDRs and environment]
Scope version	[Version number and date]
Approved activities	[Methods and test cases permitted]
Excluded activities / assets	[Explicit exclusions]
Testing dates and window	[Start/end, time zone]
Data classification	[Public / internal / confidential / personal / sensitive]
Assessor details	[Internal / external, employer, identity, NDA status]
Stop conditions and contacts	[System owner, CISO/SOC, DPO, emergency number]
Approvals	[Requester, system owner, CISO/delegate, Legal/DPO if required, provider if required]
Signatures and timestamps	[Digital or physical signatures, date/time]

8.2 Document 2 – Scope and RoE Form

Field	Template value / instruction
Engagement ID / RoE version	[Link to authorization record]
In-scope assets	[Asset ID, owner, hostname/IP/CIDR, environment, tag]
Out-of-scope assets	[All unlisted systems, third-party assets without permission, live data stores unless separately approved]
Testing window	[Approved dates and off-peak time]
Permitted techniques	[Passive recon, approved scanning/enumeration; exploitation only in lab]
Prohibited techniques	[DoS, destructive actions, persistence, malware, data exfiltration, unauthorized social engineering]
Rate / safety limits	[Approved rate, service monitoring, stop thresholds]
Evidence rules	[Minimum evidence, encrypted repository, retention date]
Escalation	[Named contacts and stop-work procedure]

Change control	[No scope change without re-approval]

8.3 Document 3 – Finding Report (structured)

Field	Example / rule
Finding ID	FND-UNI-2026-001
Engagement ID	UNI-SEC-2026-001
Title	Example: SQL injection indicator in isolated student-portal replica
Affected asset	UNI-PORTAL-LAB-001 (192.168.56.20)
Scope validation	IN-SCOPE; RoE v1.0
Severity / CVSS	[Score and vector; assessor to justify]
Description	[What was observed; distinguish evidence from inference]
Impact	[Confidentiality / integrity / availability impact]
Evidence	[Redacted request/response, timestamp, screenshot of synthetic data only]
Reproduction conditions	[Lab-only steps; no production exploit instructions]
Remediation	[Parameterized queries, input validation, least privilege, regression tests]
Owner / due date	[System owner; date per severity SLA]
Status	NEW / TRIAGED / IN_PROGRESS / FIXED / RETESTED / CLOSED
Disclosure classification	PRIVATE / RESTRICTED / PUBLIC-APPROVAL-REQUIRED
Retest result	[Pass/fail, date, tester, authorization reference]

Structured output example (JSON-like record for the disclosure tracker):

{"finding_id":"FND-UNI-2026-001","engagement_id":"UNI-SEC-2026-001","asset_id":"UNI-PORTAL-LAB-001","scope_tag":"IN-SCOPE","severity":"High","status":"NEW","disclosure":"PRIVATE","owner":"Portal System Owner","due_date":"[YYYY-MM-DD]"}

8.4 Document 4 – Disclosure and Remediation Record

Field	Template value / instruction
Finding ID / Engagement ID	[Link to finding and engagement]
Recipient	[Verified system owner / CISO / vendor contact]
Initial report date/time	[Timestamp]
Severity and triage decision	[CVSS, impact, incident flag]
Disclosure route	[Coordinated private / restricted incident channel]
Remediation deadline	[30 days critical; 90 days default, unless approved changed policy]
Status updates	[Date, sender, summary, next action]

Escalation date / decision	[CISO / legal / DPO decision]
Retest authorization and result	[Approval, date, result]
Closure date	[Owner acceptance and evidence reference]

8.5 Document 5 – Pre-engagement Checklist

- ☐ Authorization signed and verified; Engagement ID assigned.
- ☐ Scope and asset tags match the signed RoE.
- ☐ System owner and test window confirmed.
- ☐ Legal/privacy and provider approvals completed.
- ☐ Assessor identity, NDA and access expiry verified.
- ☐ Host-only lab configuration checked; synthetic data prepared.
- ☐ Logging and evidence repository available.
- ☐ Escalation contacts and stop-work process tested.

8.6 Document validation test entries

Test input	Class	Expected result
Authorization form complete with valid signatures and exact asset list.	Valid	Accepted; Engagement ID issued; state becomes AUTHORIZED after other gates pass.
Form has all fields but system-owner signature is missing.	Boundary	Flagged as incomplete; cannot start until signature is supplied.
Request has no authorization form or approver.	Invalid	Rejected; no testing activity permitted.
RoE lists UNI-PORTAL-LAB-001 but tester requests UNI-PAY-EXT-001.	Invalid / out of scope	Blocked by asset-tag check; new permission required.
Finding report contains real student names or copied records.	Invalid evidence	Quarantine access, remove unnecessary data under incident/legal direction, notify DPO; do not circulate.
Finding report has valid ID, asset, severity, owner and private disclosure route.	Valid	Accepted into disclosure tracker and counted in metrics.

8.7 Integration

The Finding Report's finding_id, asset_id, severity, status and due_date fields feed the disclosure tracker. The tracker records time-to-notify, time-to-remediate and overdue status. Task 10 uses these fields to calculate process measures. The authorization and RoE documents provide the Engagement ID and scope tag used to validate each finding.

TASK 9 – Integrate, Test and Refine the Framework (4 Marks)

9.1 End-to-end integration

Authorization → Scope/RoE → Legal and privacy check → Threat model → Isolated-lab test → Finding Report → Coordinated disclosure → Remediation → Retest → Closure. The document library provides the forms at each stage, and the central governance register records all state changes.

9.2 Walkthrough: hypothetical student portal assessment

Stage	Walkthrough action	Evidence / decision
Request	Academic IT department requests pre-upgrade review of student portal.	Request form; business purpose; proposed dates.
Authorization	Governance team verifies CISO/delegate and portal owner approval; issues UNI-SEC-2026-001.	Signed authorization; Engagement ID.
Scope/RoE	Only portal lab replica UNI-PORTAL-LAB-001 is approved for hands-on testing; production portal is not approved for exploitation.	RoE v1.0; asset tag IN-SCOPE for lab; production excluded from exploit testing.
Legal/privacy	Portal can hold student personal data; DPO/legal review requires synthetic data and no copying of production records.	Legal checklist; data minimisation condition.
Threat model	Credential theft, injection, insider misuse and hacktivist defacement are considered.	Threat model and prioritized test cases.
Lab test	Kali VM 192.168.56.10 tests DVWA/portal replica 192.168.56.20 on host-only network.	VM settings, routes, ping and lab-only discovery record.
Finding	A SQL-injection indicator is found in the deliberately vulnerable replica using synthetic records.	FND-UNI-2026-001; severity assessed; evidence redacted.
Disclosure	Private report sent to portal owner and CISO; remediation target assigned according to severity.	Disclosure Record; due date and status.
Remediation/retest	Developer applies parameterized queries; authorized retest confirms expected safe behaviour.	Fix evidence; retest approval and result.
Closure	Access revoked, evidence retained under policy and engagement closed.	Closure checklist and audit log.

9.3 Systematic test cases

Test ID	Test condition	Expected behaviour	Pass condition
TC-01	Missing authorization	Reject before any activity.	No Engagement ID / no AUTHORIZED state.
TC-02	Out-of-scope target requested	Asset-tag check blocks request and alerts Governance Lead.	No traffic sent to target; event logged.
TC-03	Personal-data system with no DPO/legal review	Hold engagement; lab-only until review completed.	Status remains LEGAL-HOLD.
TC-04	Third-party hosted target without provider permission	Reject target from scope.	No test; permission evidence required.
TC-05	Unexpected service instability	Stop test and escalate to system owner/SOC.	Pause timestamp and incident ticket recorded.
TC-06	Critical finding is not acknowledged within target	Escalate to CISO; assess incident reporting; agree containment.	Escalation record and owner assigned.
TC-07	Disclosure deadline passes	Do not auto-publish; escalate to legal/CISO and reassess risk.	Decision logged; privacy review remains mandatory.
TC-08	Assessor access expiry reached	Disable access and close credentials/tokens.	Access revocation evidence.

9.4 Problems found and refinements

Initial weakness found in walkthrough	Refinement	Result
Out-of-scope checking relied on manual reading.	Add asset tags and an allow-list check before each test action.	Out-of-scope requests are rejected consistently.
Approval evidence could be stored in email threads only.	Create a central engagement register with immutable status history and scope version.	Approvals are searchable and auditable.
Disclosure timeline was ambiguous.	Set 30-day critical and 90-day default remediation targets, with escalation and immediate containment for urgent risk.	Owners receive clear deadlines.
Personal-data rules were too general.	Add stop-and-report rule, synthetic data, DPO/legal gate and private-only disclosure for personal-data findings.	Reduced privacy exposure.
External assessors were not covered by internal staff rules.	Add vetting, NDA, least privilege, expiry and access logging.	External testers are accountable.

Validation conclusion: the walkthrough demonstrates the complete path from request to closure. The test cases verify that the framework blocks missing authorization, out-of-scope activity and unresolved legal conflicts. The refinements make the framework more machine-checkable and auditable.

TASK 10 – Create a Scalability and Governance Evaluation (4 Marks)

The following evaluation uses the illustrative process measures supplied in the assignment model answer. They are scenario estimates for comparing governance at two scales, not measured results from an actual university deployment.

10.1 Evaluation scenarios

Scenario	Systems	Testers	Programme description
Small programme	5 systems	2 internal testers	One department; limited asset owners; centralized approval.
Large programme	Approximately 200 systems	20 internal + 10 external testers	Whole university; multiple departments, system owners and third-party assessors.

10.2 Process measures

Process	Small programme	Large programme	Interpretation
Approval turnaround	~4 hours	~36 hours	More stakeholders and review dependencies increase delay.
Scope coverage	100%	82%	Large scope and coordination complexity leave gaps.
Disclosure steps	5	9	More owners, vendors and approval gates increase coordination steps.

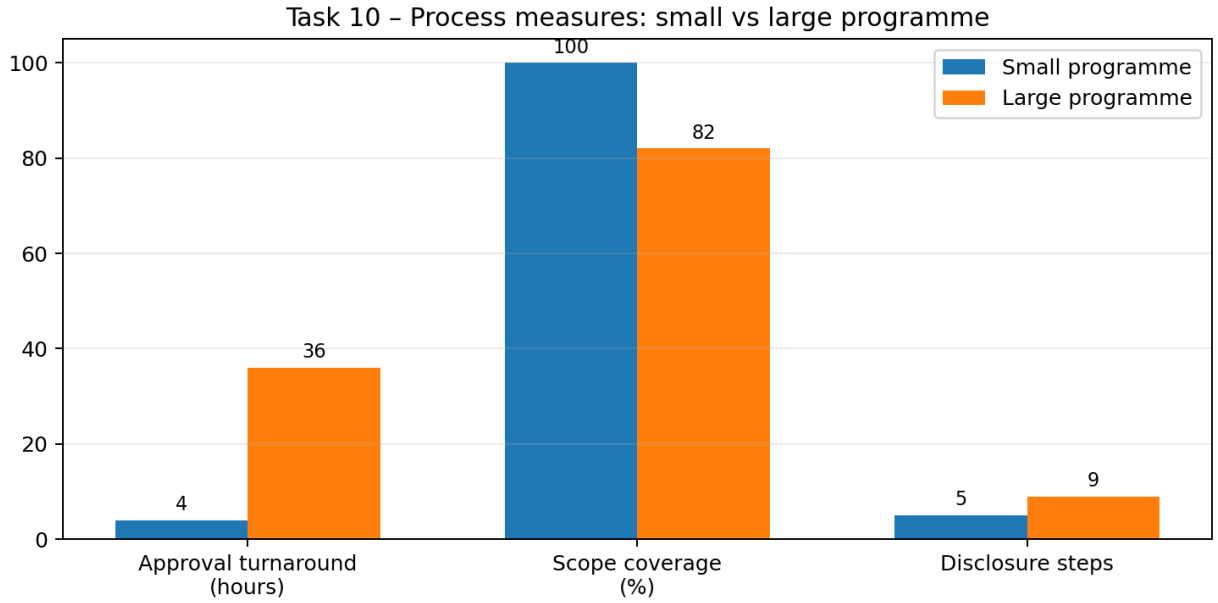


Chart 1. Comparison of the three process measures. The chart uses the illustrative values shown in the table.

10.3 Interpretation

- Approval turnaround increases from about 4 to 36 hours because large engagements require coordination across departments, system owners, legal/privacy reviewers and external assessors.
- Scope coverage decreases from 100% to 82%, indicating that a large asset inventory is harder to maintain manually and may contain unreviewed or unowned assets.
- Disclosure steps increase from 5 to 9 because findings may involve multiple system owners, vendors, privacy reviewers and management escalation.

10.4 Governance refinements based on evaluation

Observed issue	Governance refinement	Expected measure improved
Approval delay	Delegate low-risk approvals to trained system-owner delegates within policy; keep high-risk and personal-data engagements with CISO/legal/DPO review.	Approval turnaround.
Coverage gap	Maintain a central asset register with mandatory owner, criticality and scope tag; run quarterly ownership reconciliation.	Scope coverage.
More disclosure handoffs	Use one finding ID, standardized severity, common disclosure record and automated reminders/escalation.	Disclosure steps and overdue findings.
External assessor overhead	Standard onboarding pack: vetting, NDA, conflicts, training, access expiry and evidence-handling rules.	Onboarding time and audit completeness.
Prioritization challenge	Risk-based schedule: critical identity, student-record and research systems receive priority; low-risk assets rotate through the cycle.	Risk-weighted coverage.

Evaluation conclusion: the framework scales only if manual coordination is reduced without weakening high-risk gates. Delegated approval is appropriate for low-risk, well-bounded work; personal-data, production-impacting and third-party engagements retain stronger review.

TASK 11 – Defend the Framework Under a Changed Requirement (4 Marks)

11.1 Changed requirement

The university now performs continuous assessments and uses external assessors more frequently. Data-protection rules are stricter, disclosure deadlines are shorter, and the framework must remain easy to govern and extend.

11.2 Retain, modify, replace and redesign

Decision	Component	Revised treatment
Retain	Authorization workflow	Keep written approval, Engagement ID, approver authority and audit record.
Retain	Scope and RoE	Keep exact asset allow-list, exclusions, testing windows and stop conditions; version every change.
Retain	Isolated lab	Keep host-only lab for exploit validation and training.
Modify	Disclosure timeline	Adopt 30 days for standard remediation and 7 days for critical as the changed-requirement target; urgent containment remains immediate.
Modify	Legal/privacy mapping	Add DPDP Act/Rules readiness and commencement-date checks; strengthen minimisation, retention and breach handling.
Modify	External assessor controls	Require due diligence, NDA, conflict declaration, named personnel, least privilege, MFA, device controls and access expiry.
Replace	Manual approval log	Use a workflow/ticketing register with role-based access, version history, timestamps and audit export.
Redesign	One-off assessment model	Use a continuous assessment pipeline with scheduled scope reviews, periodic approvals and event-triggered reassessment.

11.3 New component – External-Assessor Governance Module

Control	Requirement	Integration point
Vetting	Verify company identity, references, personnel,	Before authorization.

	competence, conflicts and insurance where required.	
Contract / NDA	Sign confidentiality, data-handling, breach-notification, subcontractor and deletion clauses.	Legal review and document library.
Least-privilege access	Issue named accounts, MFA, time-bound access and only the minimum systems needed.	Authorization and scope allow-list.
Tool / device controls	Approve devices and tools; prohibit unapproved cloud uploads and removable-media copying.	RoE and evidence handling.
Monitoring	Log access, testing windows, key actions and data access; provide university observer where appropriate.	Governance register and SOC.
Offboarding	Revoke accounts, keys, tokens and VPN access; collect deletion attestation and close findings.	Engagement closure.

11.4 Continuous assessment pipeline

Proposed cycle: asset inventory update → risk-based scope approval → scheduled non-disruptive checks → isolated-lab validation of exploitable issues → finding triage → private disclosure → remediation SLA → authorized retest → metrics and quarterly governance review. Any new asset, owner change, vendor change, critical vulnerability or data-flow change triggers a scope/legal review.

11.5 Shorter disclosure policy

Severity	Initial notification target	Remediation target under changed requirement	Escalation
Critical	Within 1 business day; immediate phone/SOC alert if actively exploitable.	7 calendar days, or immediate containment plus documented exception plan.	CISO and system owner same day; incident reporting assessment.
High	Within 3 business days.	30 calendar days.	CISO if overdue or exposure remains material.
Medium	Within 5 business days.	30 calendar days where feasible; otherwise risk-approved plan.	System owner and Governance Lead.
Low	Within 5 business days.	90 calendar days or next planned release.	Track in backlog and review quarterly.

The changed requirement specifically calls for a shorter disclosure timeline. The 30-day standard and 7-day critical target are programme targets and must be resourced; they do not replace statutory incident reporting obligations or immediate containment duties.

11.6 Evidence-based defence

- Task 9 walkthrough: demonstrates an end-to-end engagement with authorization, scope, privacy review, lab test, finding, disclosure, remediation and closure.
- Task 10 evaluation: demonstrates that scale increases approval time and disclosure steps while reducing scope coverage; delegated approvals, asset automation and standardized assessor onboarding address those weaknesses.
- Task 4 legal mapping: ties authorization, data minimisation, confidentiality and incident response to the IT Act, DPDP transition and CERT-In controls.
- Task 6 disclosure process: supplies named recipients, report format, remediation windows, status logging and escalation; the revised 30/7-day targets meet the changed programme requirement.

11.7 Remaining trade-offs and future improvements

Trade-off / limitation	Impact	Future improvement
Shorter remediation windows	Can pressure development teams and increase rushed fixes.	Risk-based exceptions, dedicated remediation capacity, compensating controls and retest automation.
Continuous assessment	More alerts and coordination overhead; risk of assessment fatigue.	Tune test frequency by asset criticality and use change-aware scheduling.
External assessors	More contracts, onboarding and access monitoring.	Central assessor registry, standardized clauses and automated expiry.
Lab versus production fidelity	Lab replicas may not reproduce every production configuration or integration.	Configuration parity checks, sanitized staging replicas and owner-approved non-invasive production review.
DPDP phased commencement	Requirements and dates may change through notifications and rules.	Quarterly legal review and a commencement-date field in every engagement checklist.

Defence conclusion: the revised design retains the core safeguards but introduces continuous governance, shorter service levels, stronger privacy checks and a dedicated external-assessor module. The remaining limitations are acknowledged and managed through risk-based scheduling, automation and periodic legal review.

Final Framework Summary

Governance layer	Core rule	Primary evidence
Authorization	No written approval, no test.	Authorization Form / Engagement Register
Scope and RoE	Only asset-tagged, approved targets and methods.	Scope/RoE Form / Pre-engagement Checklist
Legal and privacy	Legal gate before systems containing personal data are assessed.	Legal Compliance Checklist / DPO decision
Threat model	Classify actors by authorization, intent, capability and affiliation.	Threat Model Register
Ethics	Least intrusion, confidentiality, integrity, data minimisation and stop-work.	Code of Conduct / Activity Log
Lab	Hands-on exploitation only in host-only isolated lab.	Lab Configuration Record
Finding and disclosure	Private coordinated reporting, tracked remediation and approved retest.	Finding Report / Disclosure Record
Governance and scale	Central audit trail, risk-based coverage and external assessor controls.	Metrics Dashboard / Closure Record

Final Conclusion

This assignment designs a complete ethical-hacking engagement framework for the university's authorized security-assessment programme. The framework connects the people, permissions, scope, legal requirements, threat model, isolated lab, findings and disclosure process through a central governance record. It distinguishes authorization from legality and appropriateness: written permission is necessary, but every activity must also comply with law, contracts, privacy expectations and the university's operational risk limits.

The framework is reusable for the initial 20 systems and 50 staff and can scale to university-wide continuous assessments and external testers. Its most important operating rule is: no valid authorization and scope, no testing. Practical validation remains confined to an isolated lab, and vulnerabilities are reported privately to authorized owners with clear remediation and escalation targets.

References

- Government of India, The Information Technology Act, 2000 (as amended), India Code: https://www.indiacode.nic.in/indiacode/handle/123456789/1999
- Government of India, Digital Personal Data Protection Act, 2023, Act 22 of 2023.
- Ministry of Electronics and Information Technology, G.S.R. 843(E), DPDP Act commencement notification, 13 November 2025: https://egazette.gov.in/WriteReadData/2025/267647.pdf

- Ministry of Electronics and Information Technology, Digital Personal Data Protection Rules, 2025, Gazette notification: https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686cadad39.pdf
- Indian Computer Emergency Response Team (CERT-In), Directions under section 70B(6) of the Information Technology Act, 2000, 28 April 2022: https://cert-in.org.in/PDF/CERT-In_Directions_70B_28.04.2022.pdf
- United States Code, Title 18, Section 1030 – Fraud and related activity in connection with computers: https://uscode.house.gov/us/usc/119-124/t18/s1030/
- Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011.
- ITA14 Ethical Hacking Assignment 1 question paper and supplied Model Answer Key & Evaluation Scheme (user-provided course document).